

Simulazione della prova pratica d'esame – gestione delle richieste di rimborso spese aziendali

Parte 1 – Indicazioni generali valide per la prova pratica

Obiettivo della prova

La prova è finalizzata a valutare la capacità dell'esaminando di progettare e sviluppare una applicazione web full stack funzionante, con autenticazione, gestione di dati relazionali, interazione tra frontend e backend tramite API e persistenza su database.

L'applicazione sarà valutata principalmente per il comportamento osservabile dall'utente tramite il frontend: le pagine devono consentire di svolgere i casi d'uso richiesti, rispettando le regole funzionali, le validazioni e le autorizzazioni previste.

Principio generale sulle specifiche

Le specifiche funzionali sono vincolanti: l'applicazione deve consentire agli utenti di svolgere correttamente le operazioni richieste.

Le indicazioni tecniche, il modello dei dati suggerito e gli esempi di endpoint API rappresentano una possibile soluzione implementativa. Il candidato può adottare scelte diverse, purché il risultato sia funzionalmente equivalente, coerente, testabile e adeguato ai requisiti della prova.

Uso di template e codice sviluppato in precedenza

L'esaminando può utilizzare template, strutture di progetto, frammenti di codice, componenti o esempi sviluppati in precedenza durante le lezioni, le esercitazioni o lo stage.

L'uso di materiale preesistente è consentito, purché l'esaminando sia in grado di adattarlo al caso d'uso richiesto, integrarlo correttamente nell'applicazione e spiegarne il funzionamento in sede di valutazione.

Resta responsabilità dell'esaminando verificare che il codice utilizzato sia coerente con i requisiti della prova, non contenga dati riservati o informazioni non divulgabili e non sia una semplice consegna non adattata al caso d'uso proposto.

Requisiti generali

L'applicazione deve prevedere:

- separazione tra frontend e backend;
- frontend web realizzato con tecnologia client-side rendering (CSR);
- backend applicativo che espone API consumate dal frontend;
- database relazionale per la persistenza dei dati;
- autenticazione degli utenti;
- protezione delle funzionalità e dei dati riservati ed eventuale gestione di funzionalità pubbliche espressamente previste dal caso d'uso;

- validazione lato server dei dati ricevuti;
- un set iniziale di dati realistici, sufficiente per testare tutti i casi d'uso previsti;
- uno strumento per il test delle API, come Swagger, Postman, Insomnia o equivalente;
- codice organizzato, leggibile e coerente con le buone pratiche del framework scelto.

Non è obbligatorio utilizzare uno specifico linguaggio, framework o database relazionale.

Requisiti generali dell'interfaccia utente

L'interfaccia utente deve essere chiara, coerente nello stile e facilmente navigabile.

Le pagine principali devono essere accessibili da un menu o da una navigazione equivalente. Dopo il login, l'utente deve visualizzare le funzionalità riservate previste dal caso d'uso.

L'applicazione deve gestire in modo comprensibile:

- messaggi di errore;
- messaggi di conferma;
- validazioni dei form;
- stati delle entità;
- eventuali operazioni non consentite all'utente corrente.

L'interfaccia deve mostrare messaggi comprensibili in caso di errore di validazione, operazione non consentita o operazione completata correttamente.

Registrazione e autenticazione

L'applicazione deve prevedere una pagina di registrazione accessibile dalla pagina di login.

La registrazione deve consentire la creazione di un nuovo utente ordinario, compilando almeno:

- nome;
- cognome;
- email;
- password;
- conferma password.

Le specifiche del caso d'uso indicano quale tipologia di utente possa registrarsi autonomamente e quali eventuali semplificazioni siano ammesse ai fini della prova.

Quando il caso d'uso prevede ruoli differenti, la traccia specifica se il ruolo possa essere scelto durante la registrazione oppure debba essere predisposto nei dati iniziali.

La modalità adottata deve consentire di verificare agevolmente tutte le funzionalità richieste.

In caso di credenziali errate, l'applicazione deve mostrare un messaggio di errore comprensibile.

Validazioni generali

Le validazioni devono essere effettuate lato server. Le validazioni lato frontend sono utili per migliorare l'esperienza utente, ma non sostituiscono quelle lato backend.

Per la registrazione devono essere rispettate almeno le seguenti validazioni:

- nome e cognome sono obbligatori;
- email è obbligatoria, deve avere formato valido e deve essere univoca;
- password è obbligatoria;
- password e conferma password devono coincidere.

I campi obbligatori non devono accettare valori vuoti o composti solo da spazi.

Le password non devono essere salvate in chiaro, ma memorizzate in forma sicura, ad esempio tramite hash.

Sicurezza e autorizzazioni

Le pagine riservate devono essere accessibili solo agli utenti autenticati.

Le API riservate devono richiedere autenticazione.

Le operazioni disponibili devono rispettare il confine tra funzionalità riservate ed eventuali funzionalità pubbliche previste dal caso d'uso.

Eventuali limitazioni basate su ruoli o dati di competenza devono essere applicate quando richieste dalle specifiche del caso d'uso.

I controlli di autenticazione e autorizzazione devono essere eseguiti dal backend. Non è sufficiente nascondere pulsanti o pagine nel frontend.

Eventuali API pubbliche devono essere esplicitamente indicate dalla traccia.

API attese o equivalenti

Il backend deve esporre API che consentano al frontend di realizzare tutte le funzionalità richieste.

Gli endpoint indicati nella traccia rappresentano una possibile struttura REST. Il candidato può usare nomi, percorsi o organizzazione diversa, purché le operazioni siano presenti, documentabili, testabili e rispettino le stesse regole funzionali e di sicurezza.

Per ogni endpoint che riceve dati dal client devono essere previste validazioni lato server.

Registrazione e autenticazione

Le API di autenticazione devono consentire almeno:

- registrazione di un nuovo utente previsto dal caso d'uso;
- login dell'utente;
- restituzione di un token, cookie di sessione o altro meccanismo equivalente di autenticazione;
- logout, se previsto dalla tecnologia adottata.

Esempio di possibile struttura:

POST /api/utenti/register

POST /api/utenti/login

Dati iniziali e credenziali di test

L'applicazione deve essere inizializzata con dati realistici, sufficienti per testare:

- almeno un utente autenticato e, ove previsti, utenti per ciascun ruolo necessario alla verifica;
- le principali entità gestite dal sistema;
- almeno alcuni casi con stati diversi, ove siano previsti stati applicativi;
- casi utili a verificare filtri, ricerche, riepiloghi o statistiche;
- casi utili a verificare le regole di autorizzazione.

Il candidato deve fornire le credenziali degli utenti di test necessarie a verificare le funzionalità riservate e, ove previsti, i differenti ruoli applicativi.

Deve essere predisposto uno strumento per il test delle API, ad esempio Swagger, Postman, Insomnia o equivalente.

Indicazioni tecniche

L'applicazione deve essere composta almeno da:

Frontend

- applicazione web CSR;
- interfaccia per svolgere tutti i casi d'uso richiesti;
- comunicazione con il backend tramite API;
- gestione degli stati di caricamento, errore e conferma almeno nei punti principali.

Backend

- servizio applicativo che espone API consumate dal frontend;
- gestione della logica applicativa;
- gestione di autenticazione e autorizzazione;
- accesso al database;
- validazione dei dati ricevuti dal client.

Database

- database relazionale;
- tabelle e relazioni necessarie alla persistenza dei dati;
- vincoli coerenti con il modello applicativo, quando opportuno.

Note per la valutazione

La prova sarà valutata considerando in particolare:

- correttezza funzionale dell'applicazione;
- completezza dei casi d'uso implementati;
- qualità e usabilità del frontend;
- corretta implementazione di autenticazione e autorizzazione;
- corretta gestione delle validazioni;
- coerenza del modello dei dati;

- progettazione e implementazione delle API;
- possibilità di testare le API con strumenti adeguati;
- presenza di dati iniziali realistici;
- organizzazione, leggibilità e manutenibilità del codice;
- eventuale deployment dell'applicazione.

La valutazione funzionale sarà orientata anzitutto al comportamento osservabile dell'applicazione. Se una funzionalità non è disponibile dall'interfaccia utente, potrà essere verificata tramite API, ma l'assenza della funzionalità nel frontend costituisce comunque una limitazione.

Deployment e consegna

Il deployment dell'applicazione non è indispensabile, ma contribuisce all'attribuzione di punteggio aggiuntivo.

Se effettuato, l'applicazione deve essere pubblicata su un server accessibile pubblicamente. L'URL di accesso deve contenere nome e cognome dell'allievo.

Esempio:

`https://app-nome-cognome.nomehost.dominio`

Devono essere consegnati o resi disponibili:

- URL del frontend, se pubblicato;
- eventuale URL della documentazione API o dello strumento di test API;
- credenziali di test per gli utenti previsti;
- codice sorgente dell'applicazione;
- eventuali istruzioni necessarie per eseguire l'applicazione.

Parte 2 – Specifiche del caso d'uso

Titolo della prova

Gestione delle richieste di rimborso spese aziendali

Descrizione del caso d'uso

Un'azienda vuole dotarsi di un sistema per gestire le richieste di rimborso spese presentate dai dipendenti.

I dipendenti devono poter inserire richieste di rimborso relative a spese già sostenute per motivi aziendali, ad esempio trasferte, pasti, pedaggi, parcheggi o acquisti autorizzati di piccolo importo.

I responsabili amministrativi devono poter visualizzare le richieste ricevute, approvarle o rifiutarle e, per le richieste approvate, registrare l'avvenuta liquidazione del rimborso.

Il sistema deve inoltre consentire ai responsabili amministrativi di consultare un riepilogo delle richieste di rimborso, con informazioni aggregate per mese, categoria e dipendente.

Utenti e ruoli specifici

Il sistema prevede due tipi di utenti autenticati.

Dipendente

Può:

- accedere all'applicazione;
- registrarsi autonomamente come utente dell'applicazione;
- inserire una nuova richiesta di rimborso spese;
- visualizzare le proprie richieste di rimborso;
- filtrare le proprie richieste per stato, categoria e mese;
- modificare una richiesta solo se non è ancora stata valutata;
- eliminare una richiesta solo se non è ancora stata valutata;
- visualizzare lo stato di avanzamento delle proprie richieste.

Responsabile amministrativo

Può:

- accedere all'applicazione;
- visualizzare tutte le richieste di rimborso;
- filtrare le richieste per stato, categoria, dipendente e mese;
- approvare una richiesta di rimborso;
- rifiutare una richiesta di rimborso;
- registrare come liquidata una richiesta approvata;
- visualizzare statistiche e riepiloghi sulle richieste di rimborso.

Ai fini della simulazione è ammesso che la registrazione consenta di scegliere il ruolo dell'utente tra Dipendente e Responsabile amministrativo, oppure che almeno un responsabile amministrativo sia già presente nei dati iniziali. La modalità adottata deve permettere di testare agevolmente tutte le funzionalità richieste.

Pagine e funzionalità specifiche da sviluppare

L'applicazione deve prevedere almeno le seguenti pagine o sezioni funzionalmente equivalenti.

Home / Login / Registrazione

La pagina iniziale deve consentire:

- accesso alla pagina di login;
- accesso alla pagina di registrazione;
- registrazione di un nuovo utente;
- autenticazione degli utenti registrati o già presenti nei dati iniziali.

Dashboard

Dopo il login, l'utente deve accedere a una dashboard coerente con il proprio ruolo.

La dashboard deve consentire l'accesso alle funzionalità principali disponibili per l'utente autenticato.

Area dipendente

L'area dipendente deve consentire di:

- visualizzare l'elenco delle proprie richieste di rimborso;
- filtrare le richieste per stato, categoria e mese;
- creare una nuova richiesta di rimborso;
- visualizzare il dettaglio di una richiesta;
- modificare una richiesta non ancora valutata;
- eliminare una richiesta non ancora valutata.

Per ogni richiesta devono essere visibili almeno:

- data della spesa;
- categoria;
- importo;
- descrizione;
- stato;
- eventuale data di valutazione;
- eventuale data di liquidazione.

Area responsabile amministrativo

L'area responsabile amministrativo deve consentire di:

- visualizzare l'elenco di tutte le richieste di rimborso;
- filtrare le richieste per stato, categoria, dipendente e mese;
- visualizzare il dettaglio di una richiesta;
- approvare una richiesta in attesa;
- rifiutare una richiesta in attesa, indicando eventualmente una motivazione;
- registrare come liquidata una richiesta approvata.

Riepilogo e statistiche

L'area responsabile amministrativo deve includere una pagina di riepilogo che mostri dati aggregati sulle richieste di rimborso.

La pagina deve consentire almeno di visualizzare, per mese e categoria:

- numero di richieste presentate;
- totale degli importi richiesti;
- totale degli importi approvati;
- totale degli importi liquidati.

Devono essere previsti filtri almeno per:

- mese o periodo;
- categoria;
- dipendente.

I dati possono essere presentati in forma tabellare e, opzionalmente, grafica.

Requisiti funzionali specifici obbligatori

Devono essere implementate almeno le seguenti regole funzionali:

- solo gli utenti autenticati possono accedere alle pagine riservate;
- un dipendente può vedere solo le proprie richieste di rimborso;
- un responsabile amministrativo può vedere tutte le richieste di rimborso;
- una nuova richiesta assume lo stato iniziale In attesa;
- un dipendente può modificare o eliminare solo le proprie richieste in stato In attesa;
- una richiesta approvata, rifiutata o liquidata non può essere modificata dal dipendente;
- una richiesta può essere approvata o rifiutata solo da un responsabile amministrativo;
- una richiesta può essere liquidata solo se è già stata approvata;
- una richiesta rifiutata non può essere liquidata;
- le statistiche devono essere visibili solo ai responsabili amministrativi.

Stati della richiesta di rimborso

I possibili stati di una richiesta di rimborso sono:

- In attesa;
- Approvata;
- Rifiutata;
- Liquidata.

È possibile utilizzare nomi equivalenti, purché la logica funzionale sia chiara e coerente.

Ricerca, filtri, riepiloghi e statistiche

L'applicazione deve consentire le ricerche e i filtri previsti dal caso d'uso.

L'elenco delle richieste deve supportare filtri almeno per:

- stato;
- categoria;
- mese o periodo;
- dipendente, solo per i responsabili amministrativi.

La pagina di riepilogo riservata ai responsabili amministrativi deve mostrare i dati aggregati per mese e categoria, con i filtri indicati nella sezione dedicata.

Validazioni specifiche

Devono essere applicate almeno le seguenti validazioni lato server:

- la data della spesa è obbligatoria;
- l'importo deve essere maggiore di zero;
- la richiesta deve essere associata a una categoria esistente;
- la descrizione della spesa deve essere non vuota;
- il riferimento al giustificativo, se previsto, non deve essere composto solo da spazi;
- lo stato della richiesta deve appartenere all'insieme degli stati previsti;
- la data di valutazione, se presente, non può essere precedente alla data di inserimento della richiesta;
- la data di liquidazione, se presente, non può essere precedente alla data di approvazione.

Regole di sicurezza specifiche

Le API e le pagine riservate devono essere protette tramite autenticazione.

Le operazioni disponibili devono dipendere dal ruolo dell'utente autenticato.

Il sistema deve impedire che un dipendente possa accedere, modificare o eliminare richieste di rimborso appartenenti ad altri dipendenti.

Le funzionalità di approvazione, rifiuto, liquidazione e visualizzazione delle statistiche devono essere disponibili solo ai responsabili amministrativi.

API specifiche attese

API con autenticazione

Richieste di rimborso

Operazioni minime richieste:

- elenco delle richieste, con filtri;
- dettaglio di una richiesta;
- creazione di una richiesta;
- modifica di una richiesta;
- eliminazione di una richiesta;
- approvazione di una richiesta;
- rifiuto di una richiesta;
- liquidazione di una richiesta approvata.

Esempio:

GET /api/rimborsi

GET /api/rimborsi/{id}

POST /api/rimborsi

PUT /api/rimborsi/{id}

DELETE /api/rimborsi/{id}

PUT /api/rimborsi/{id}/approva

PUT /api/rimborsi/{id}/rifiuta

PUT /api/rimborsi/{id}/liquida

La lista delle richieste deve supportare filtri almeno per stato, categoria, mese o periodo e, per i responsabili amministrativi, dipendente.

Categorie di spesa

Operazioni minime richieste:

- elenco delle categorie disponibili.

Esempio:

GET /api/categorie-spesa

Le categorie possono essere inizializzate con dati realistici. La gestione CRUD delle categorie non è obbligatoria.

Statistiche

Operazioni minime richieste, riservate ai responsabili amministrativi:

- riepilogo delle richieste per mese e categoria;
- calcolo del totale degli importi richiesti;
- calcolo del totale degli importi approvati;
- calcolo del totale degli importi liquidati;
- filtri almeno per mese o periodo, categoria e dipendente.

Esempio:

GET /api/statistiche/rimborsi?mese=2026-05&categoryid=1&dipendentid=12

Risposta esemplificativa:

```
[
  {
    "mese": "2026-05",
    "categoria": "Trasferta",
    "numeroRichieste": 8,
    "totaleRichiesto": 640.50,
    "totaleApprovato": 590.50,
    "totaleLiquidato": 420.00
  }
]
```

API senza autenticazione

Nessuna API pubblica prevista.

Modello dei dati suggerito

Per realizzare le funzionalità richieste si suggerisce il seguente modello dei dati.

Utente

Campi suggeriti:

- UtenteID;
- Nome;
- Cognome;
- Email;
- Password;
- Ruolo.

CategoriaSpesa

Campi suggeriti:

- CategoricalID;
- Descrizione.

RichiestaRimborso

Campi suggeriti:

- RichiestaID;
- DataInserimento;
- DataSpesa;
- CategoricalID;
- Importo;
- Descrizione;
- RiferimentoGiustificativo;
- Stato;
- DipendenteID;
- DataValutazione;
- ResponsabileValutazioneID;
- MotivazioneRifiuto;
- DataLiquidazione.

Il modello dei dati proposto è indicativo. Il candidato può modificarlo o integrarlo, purché la soluzione permetta di soddisfare correttamente i requisiti funzionali, le validazioni, i filtri, le statistiche e le regole di sicurezza previste.